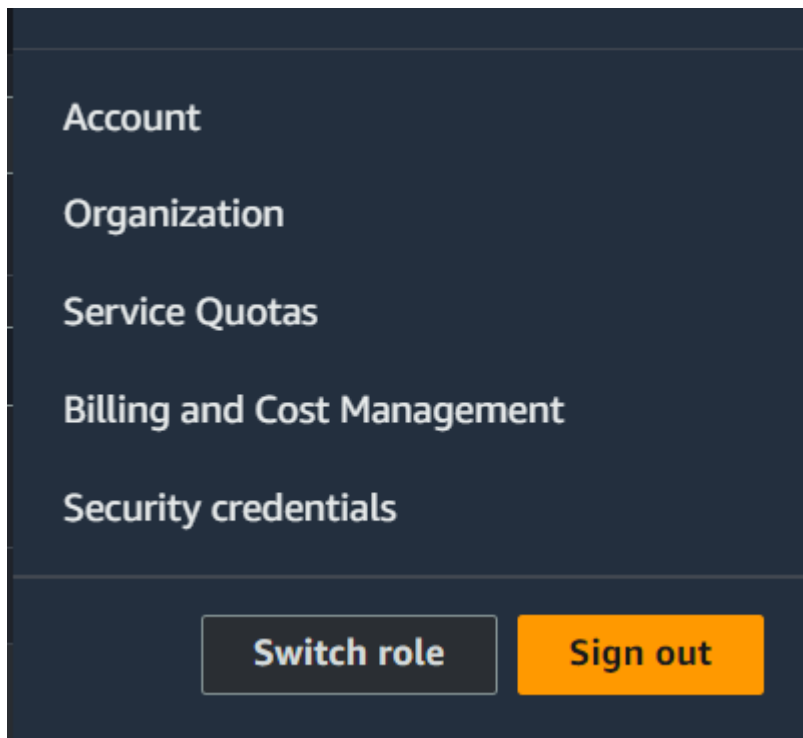
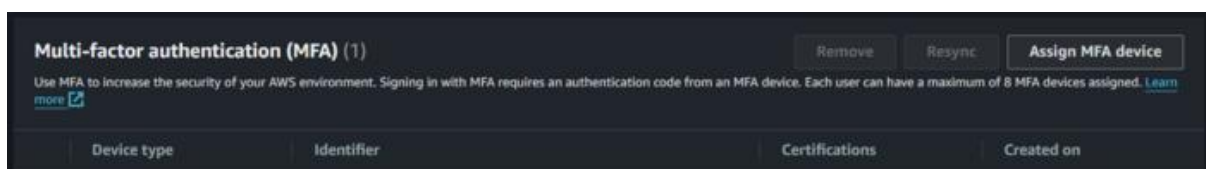


Steps To Create MFA for Root and IAM Users - Virtual MFA Devices

Step 1: Login to the AWS Management console and in the navigation bar on the upper right corner, select the account for which you wish to add the MFA device. From the drop down shown below, choose the option security credentials. This will take you to [IAM](#) Global console where you can manage the overall security of your account.



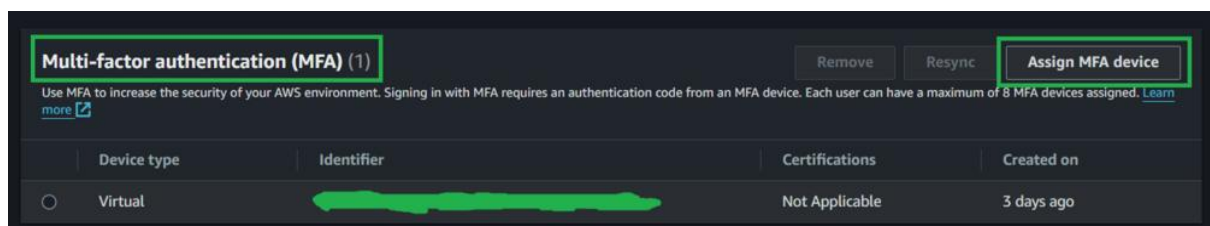
Step 2: Scroll down to the MFA options listed. This allows you to add MFA devices.



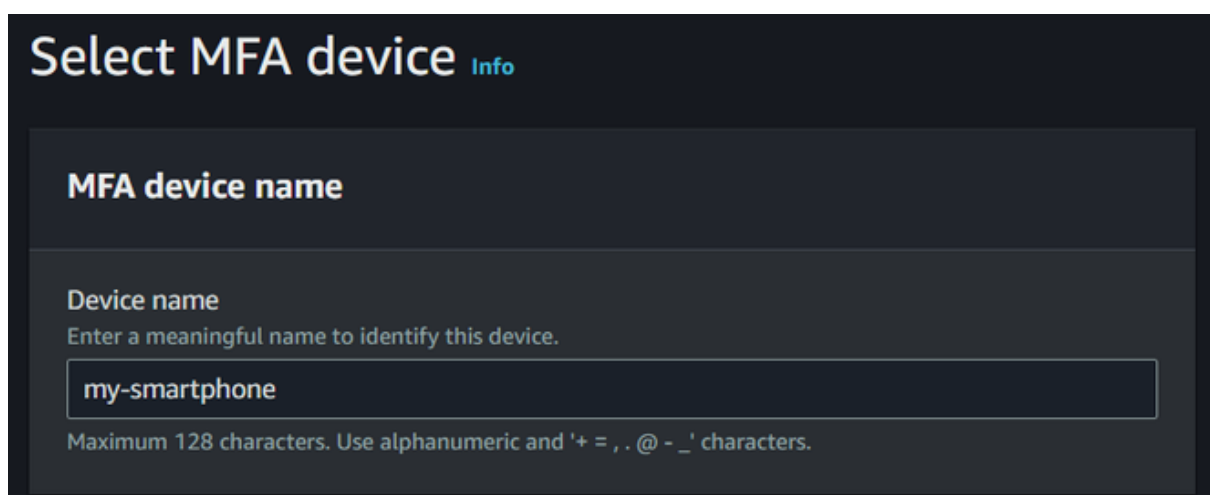
Step 3: Download Authy from Twilio in your smartphone from Google Play Store/Apple App Store



Step 4: After downloading the application of your choice, head over to the MFA section in the [IAM](#) console. Click on the assign MFA device option.



Step 5: After you have clicked next on your Assign MFA Device option, you will be prompted to choose a name for your device. In this example I have considered the name as '**my-smartphone**'.



Step 6: After typing in the name, when you scroll down you will see the following choices. Select '**Authenticator App**' and click on next.

MFA device

Select an MFA device to use, in addition to your username and password, whenever you need to authenticate.



Authenticator app

Authenticate using a code generated by an app installed on your mobile device or computer.



Security Key

Authenticate using a code generated by touching a YubiKey or other supported FIDO security key.



Hardware TOTP token

Authenticate using a code displayed on a hardware Time-based one-time password (TOTP) token.

Cancel

Next

- You will be taken to the next page where you will click on the **"Show QR Code"** button as shown below.

Set up device Info

Authenticator app

A virtual MFA device is an application running on your device that you can configure by scanning a QR code.

1

Install a compatible application such as Google Authenticator, Duo Mobile, or Authy app on your mobile device or computer.

[See a list of compatible applications](#) 

2

Show QR code

Open your authenticator app, choose **Show QR code** on this screen, then use the app to scan the code. Alternatively, you can type a secret key. [Show secret key](#)

Fill in two consecutive codes from your MFA device.

3

MFA code 1

MFA code 2

Cancel

Previous

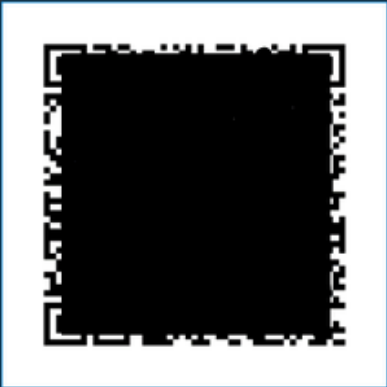
Add MFA

- This reveals the QR code. Now, in your authenticator application, click on add a new device option. Scan the following QR Code. Type in the 6 - digit code you see on your mobile phone app in MFA code.
- When your code refreshes after 60 seconds, a new code will appear. Type this in the MFA code 2 field and click on Add MFA.

1

Install a compatible application such as Google Authenticator, Duo Mobile, or Authy app on your mobile device or computer.
[See a list of compatible applications](#)

2



Open your authenticator app, choose **Show QR code** on this page, then use the app to scan the code. Alternatively, you can type a secret key.
[Show secret key](#)

3

Fill in two consecutive codes from your MFA device.

MFA code 1

MFA code 2

Cancel

Previous

Add MFA

- If you have followed all the steps as stated, you will see that now when you navigate to your IAM dashboard, it displays that you have MFA enabled for your account.

IAM Dashboard

Security recommendations

✓

Root user has MFA
Having multi-factor authentication (MFA) for the root user improves security for this account.

✓

You have MFA
Having multi-factor authentication (MFA) for the IAM user improves security for this account.

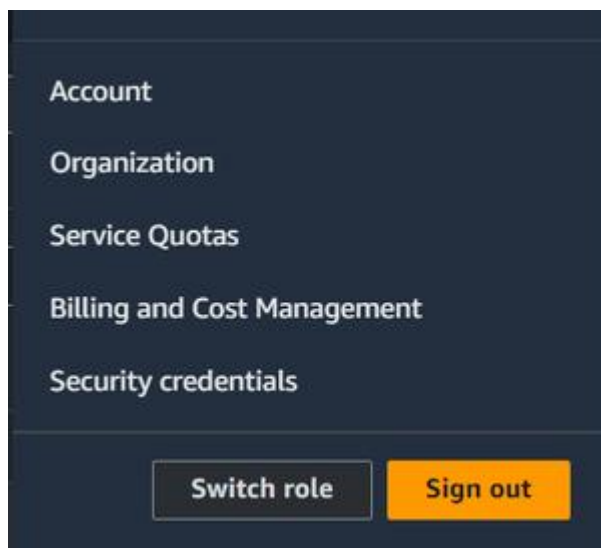
✓

Your not have any active access keys that have been unused for more than a year.
Deactivating or deleting unused access keys improves security.

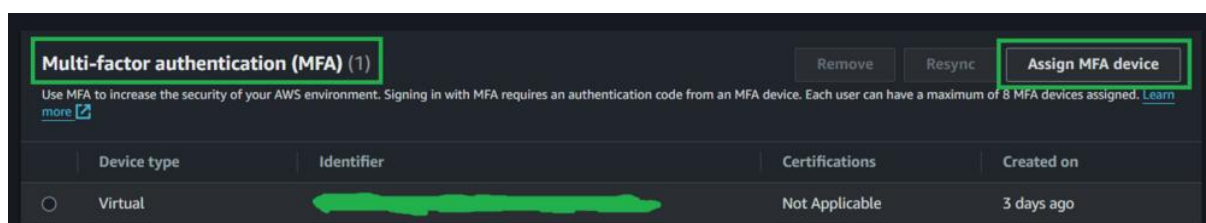
Setting Up MFA Using Hardware Devices

Setting up MFA using one of the hardware device options is similar to that of virtual authentication applications. It involves the following slight changes:

- **Get a hardware MFA Device:** To enable MFA authentication using one of the hardware devices you must first arrange one of these devices.
- **FIDO Security Keys:** FIDO certified security keys can be ordered for free from AWS console for US based customers. Other users can buy keys like Yubico for themselves. Then the process of adding these to their accounts is:
 - Login to the AWS Management console and in the Navigation bar on the upper right corner, select your account for which you wish to add the security key
 - . From the drop down shown below, choose the option security credentials.
 - This will take you to IAM Global console where you can manage the overall security of your account.



- Next, on the AWS iam console, scroll down to see your MFA devices listed. Click on the add Assign MFA Device option.



- Select a suitable name for your device and choose the option Security Keys from the list as shown below. Then click on Next.

MFA device name

Device name

Enter a meaningful name to identify this device.

Device name

Maximum 128 characters. Use alphanumeric and '+ = , . @ - _' characters.

Enter a name

MFA device

Select an MFA device to use, in addition to your username and password, whenever you need to authenticate.



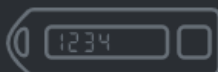
Authenticator app

Authenticate using a code generated by an app installed on your mobile device or computer.



Security Key

Authenticate using a code generated by touching a YubiKey or other supported FIDO security key.



Hardware TOTP token

Authenticate using a code displayed on a hardware Time-based one-time password (TOTP) token.

Cancel

Next

- Next, connect the device to your computer. And tap it. This successfully configures your security key for use with AWS. Next time you login into your AWS account, you will need to use your security keys.

Security key

Supported configurations for using security keys [↗](#)

Connect your security key to your device.

1



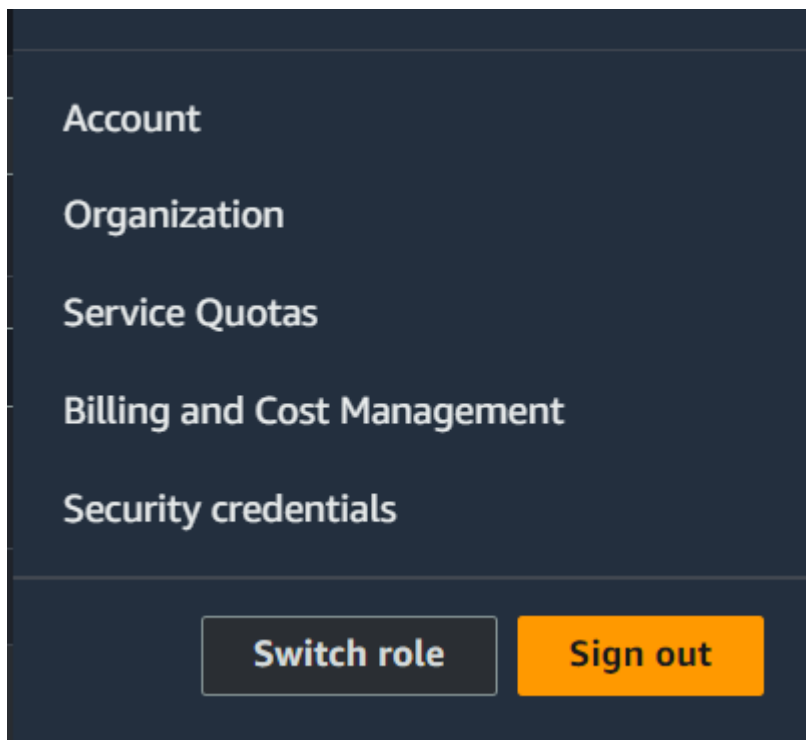
2

Tap the security key.

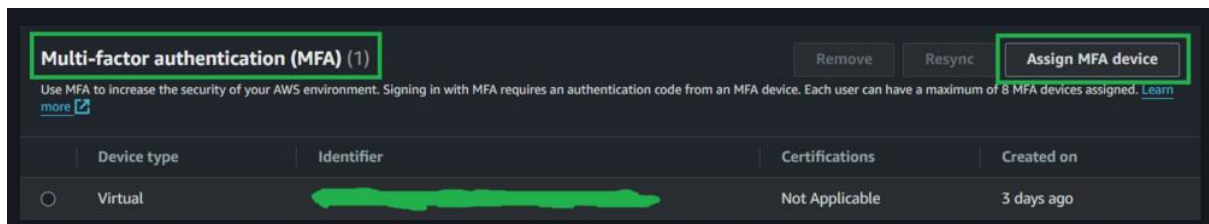
Waiting for security key...

Troubleshoot MFA [↗](#)

- **Hardware TOTP Tokens:** To add these devices for MFA follow the following steps:
 - Login to the AWS Management console and in the Navigation bar on the upper right corner, select your account for which you wish to add the security key.
 - From the drop down shown below, choose the option security credentials.
 - This will take you to IAM Global console where you can manage the overall security of your account.



- Next, on the AWS IAM console, scroll down to see your MFA devices listed. Click on the add Assign MFA Device option.



- Select a suitable name for your device and choose the option Security Keys from the list as shown below. Then click on Next.

MFA device name

Device name

Enter a meaningful name to identify this device.

Maximum 128 characters. Use alphanumeric and '+ = , . @ - _' characters.

MFA device

Select an MFA device to use, in addition to your username and password, whenever you need to authenticate.



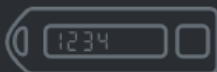
Authenticator app

Authenticate using a code generated by an app installed on your mobile device or computer.



Security Key

Authenticate using a code generated by touching a YubiKey or other supported FIDO security key.



Hardware TOTP token

Authenticate using a code displayed on a hardware Time-based one-time password (TOTP) token.

Cancel

Next

- After clicking on next you will be taken to a new page where you will have to enter the serial number of your hardware device that is located on it's back.
- Fill in this serial number on the designated field. Start the device. You will see a six digit MFA code. Enter it into the first field and wait for 30 seconds.

- A new MFA code will appear. Enter it into the second field and click on Add MFA button.
- This successfully adds the TOTP hardware device to the account. Please refer the screenshot below for your reference.

The screenshot shows the 'Set up device' page in the AWS IAM console. The page has a dark theme. At the top, there's a header 'Set up device' with an 'Info' link. Below this is a section titled 'Hardware MFA device' with a link to the 'IAM User Guide'. The main content area contains three numbered steps: 1. Enter the device serial number located on the back of the device. (Input field: Serial number) 2. Press the button on the front of the device and enter the 6-digit number that appears. (Input field: MFA Code 1) 3. Wait 30 seconds and then press the button again. Enter the second number. (Input field: MFA Code 2) At the bottom right, there are three buttons: 'Cancel', 'Previous', and 'Add MFA' (highlighted in orange).

Set up device [Info](#)

Hardware MFA device

For more information about using a hardware MFA device, see the [IAM User Guide](#) [↗](#)

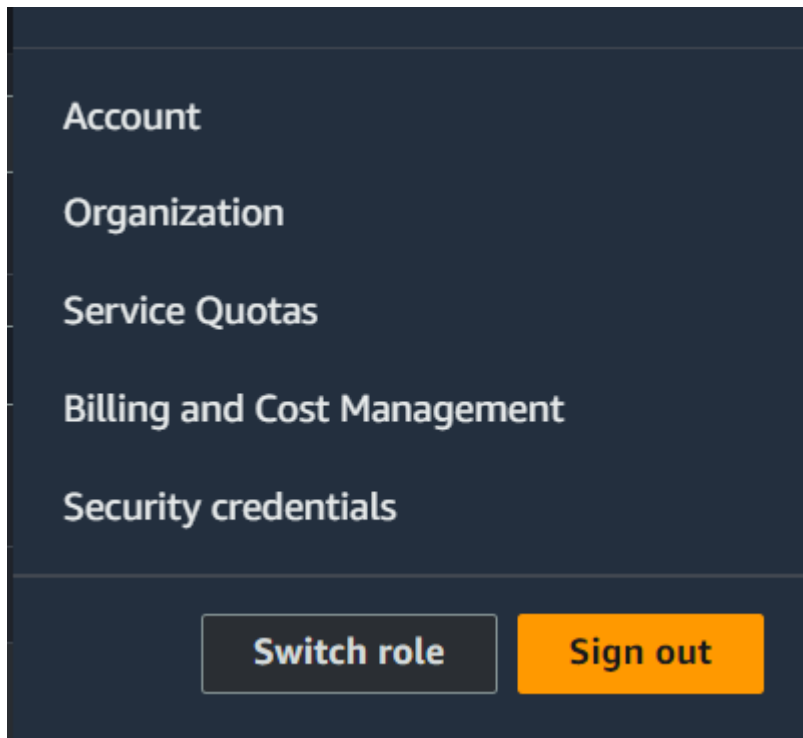
- 1 Enter the device serial number located on the back of the device.
- 2 Press the button on the front of the device and enter the 6-digit number that appears.
- 3 Wait 30 seconds and then press the button again. Enter the second number.

[Cancel](#) [Previous](#) [Add MFA](#)

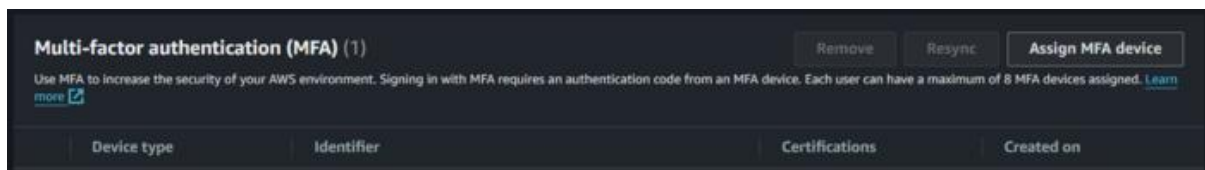
Managing MFA Devices In AWS

AWS makes it quite simple to manage your MFA Devices. Each account in AWS can have up to 8 MFA devices at any given time. All these options can be managed from the AWS IAM console under the Multi-Authentication Devices section.

- Login to the AWS Management console and in the navigation bar on the upper right corner, select your account for which you wish to add the security key.



- From the drop down shown below, choose the option security credentials. This will take you to IAM Global console where you can manage the overall security of your account.



The above console contains everything needed to work with MFA devices. It allows the addition, removal and resyncing of MFA Devices in AWS.

Best Practice Of MFA Security in AWS

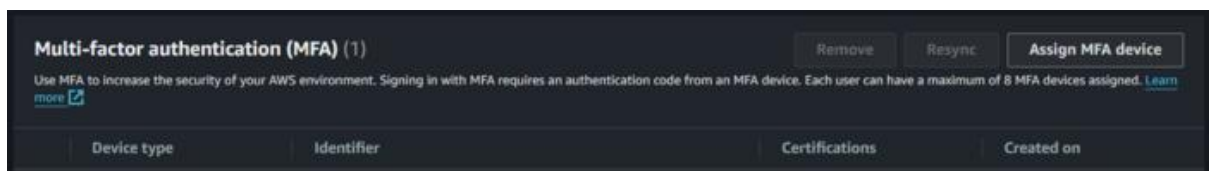
- Always add MFA devices for the root user and the IAM user.
- The physical security of your hardware devices is your responsibility. If you add them to your account and lose them, you will not be able to access your account.
- Consider adding multiple MFAs to secure your account. In case you lose any one of your devices, you will still be able to access your account and remove the device that you lost.
- Keep your MFA devices a secret. Never share the details of the specifics of your credentials with anyone.

- Always buy your MFA devices from authentic sources. Physical MFA devices that are plugged into your computer may have been tampered with.
- If you are the root user, make it a mandatory for your iam users to add MFA to their accounts. This safeguards your organization from many data breach attempts or [hacking](#) attempts where an intruder gains access to resources that he should not.
- Regularly resync your device to avoid running into any problems while you log in.

Troubleshooting Issues Of MFA Security In AWS

The issue that may arise with MFA devices is the asynchronous problem where your AWS account and your MFA device fall out of synch in time. This issue can be resolved from the AWS management console itself. To resync your MFA device, follow the following steps.

- Navigate to the MFA option in the IAM console.

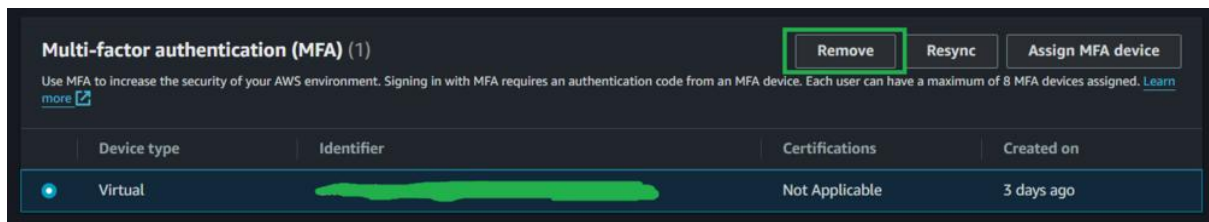


- Next, select the MFA device you want to resync and click on the Resync option.
- This opens a new prompt that asks you to enter 2 MFA codes.
- Enter 2 consecutive MFA devices that you see on your device and then click on Resync.
- This successfully resolves all the issues with your MFA device.

A screenshot of the 'Resync MFA device' prompt. The prompt has a title bar with the text 'Resync MFA device' and a close button (X). The main content area contains the instruction: 'Fill in two consecutive codes from your MFA device to resynchronize it.' Below this instruction, there are two input fields. The first field is labeled 'MFA code 1' and the second field is labeled 'MFA code 2'. At the bottom right of the prompt, there are two buttons: 'Cancel' and 'Resync'.

Disabling MFA For Root Users And IAM Users

To disable MFA devices, head over to the IAM console and under the MFA section, select the device you wish to remove. Then click on the Remove option.



- You will be prompted to confirm your decision.
- Click on Remove. This removes your devices and you can no longer use it to sign into your account.

